

Registre des Risques — TechShop SAS

Version : 1.0
Date : Juin 2026
Méthode : EBIOS RM simplifié (Ateliers 1, 3, 5) — ISO 27005:2022
Auteur : Dorian Poncelet (Consultant GRC)
Statut : Validé CODIR — Juin 2026

Rappel méthodologique EBIOS RM

Les 3 ateliers retenus pour TechShop SAS

- ATELIER 1 : Cadre et socle de sécurité
 - > Inventaire des actifs (voir inventaire-actifs.md)
 - > Identification des valeurs métier critiques
 - > Socle de sécurité ISO 27001 (voir SoA)
- ATELIER 3 : Scénarios stratégiques
 - > Identification des sources de risques (attaquants)
 - > Croisement source & valeur métier visée
 - > Cotation vraisemblance / impact BRUT
- ATELIER 5 : Traitement du risque
 - > Choix de la stratégie (Réduire/Transférer/Accepter/éviter)
 - > Contrôles ISO 27001 associés
 - > Cotation du risque RESIDUEL
 - > Validation par la direction

Ateliers 2 et 4 simplifiés : Pour une PME de 47 salariés, les ateliers Sources de risques et Scénarios opérationnels sont intégrés directement dans l'atelier 3, avec référence aux techniques MITRE ATT&CK; pour les scénarios techniques.

Échelles de cotation

Vraisemblance (V) — Probabilité d'occurrence dans les 12 mois

Niveau	Valeur	Critères EBIOS RM
Très faible	1	Scénario théorique. Aucun précédent dans le secteur e-commerce. Attaquant très sophistiqué requis.

Niveau	Valeur	Critères EBIOS RM
Faible	2	Possible mais requiert des conditions particulières. Précédents rares dans le secteur.
Élevée	3	Probable. Précédents fréquents dans le secteur. Vulnérabilité connue et exploitable.
Très élevée	4	Quasi-certain. Exploits publics disponibles. Campagnes actives observées.

Impact (I) — Gravité des conséquences sur TechShop SAS

Niveau	Valeur	Conséquences opérationnelles	Conséquences financières
Faible	1	Perturbation < 4h, résolution interne	< 1 000 €
Significatif	2	Perturbation 4h-3j, équipe IT mobilisée	1 000 € – 10 000 €
Grave	3	Perturbation > 3j, impact clients visible	10 000 € – 100 000 €
Critique	4	Interruption prolongée OU amende RGPD OU atteinte réputation irréversible	> 100 000 €

Niveaux de criticité (C = V × I)

Score	Niveau	Couleur	Action requise	Délai
1 – 4	Faible	[OK]	Surveillance annuelle	12 mois
5 – 8	Modéré	[MODERE]	Plan d'amélioration	6 mois
9 – 12	Élevé	[ELEVE]	Traitement prioritaire	3 mois
13 – 16	Critique	[CRITIQUE]	Traitement immédiat	1 mois

Sources de risques identifiées (Atelier 2 simplifié)

ID	Source	Motivation	Capacité	Pertinence TechShop
SR-01	Cybercriminel organisé	Gain financier (ransomware, revente données)	Élevée	Très pertinent — e-commerce = cible lucrative
SR-02	Script kiddie / opportuniste	Notoriété, défi technique	Faible	Pertinent — vulnérabilités WordPress connues

ID	Source	Motivation	Capacité	Pertinence TechShop
SR-03	Employé malveillant / ex-employé	Vengeance, gain personnel	Moyenne	Pertinent — turnover, accès Odoov/GW non révoqués
SR-04	Concurrent déloyal	Espionnage commercial	Faible	Peu pertinent à ce stade
SR-05	Fournisseur compromis	Vecteur tiers (supply chain)	Variable	Pertinent — dépendance Stripe, Cloudflare
SR-06	Erreur interne (non malveillante)	Aucune (accident)	N/A	Très pertinent — 47 salariés, IT peu mature

Registre des risques

Format de lecture

Chaque risque est décrit selon la structure :

- **Scénario** : Source × Vecteur × Actif ciblé
- **Cotation brute** : avant mise en place des contrôles
- **Traitement** : stratégie + contrôle ISO 27001 de référence
- **Risque résiduel** : après application des contrôles planifiés
- **NIS2** : article 21 applicable

R01 — Ransomware sur l'infrastructure OVH

Champ	Valeur
Actif ciblé	A-011 (WooCommerce), A-019 (Serveurs OVH), A-002 (Commandes)
Source de risque	SR-01 (Cybercriminel organisé)
Vecteur d'attaque	Phishing -> exécution malware -> chiffrement disques (MITRE T1566 -> T1486)
Menace	Chiffrement des données et demande de rançon
Vulnérabilité	Absence de segmentation réseau, sauvegardes non isolées (même VLAN)
Vraisemblance brute	3 — Élevée (campagnes ransomware e-commerce très actives en 2025-2026)
Impact brut	4 — Critique (arrêt total ventes, perte CA ~8 750€/jour, atteinte réputation)
Criticité brute	[ELEVE] 12/16
Stratégie	Réduire

Champ	Valeur
Contrôles ISO 27001	A.8.13 (Backup), A.8.7 (Anti-malware), A.8.20 (Segmentation réseau)
Actions de traitement	1/ Sauvegardes immutables S3 Object Lock (offline backup) ; 2/ EDR sur serveurs OVH ; 3/ Segmentation VLAN prod/admin ; 4/ Test de restauration trimestriel
Vraisemblance résiduelle	2
Impact résiduel	3 (restauration possible en < 24h avec backups testés)
Criticité résiduelle	[MODERE] 6/16
Responsable	DSI — Thomas Rivet
Échéance	T3 2026
NIS2 Art. 21	(b) Gestion des incidents, (c) Continuité des activités, (h) Sécurité de la chaîne d'approvisionnement

R02 — Fuite de données clients (breach RGPD)

Champ	Valeur
Actif ciblé	A-001 (BDD clients), A-002 (Commandes)
Source de risque	SR-01 (Cybercriminel), SR-02 (Script kiddie)
Vecteur d'attaque	Injection SQL sur WooCommerce -> exfiltration BDD (MITRE T1190 -> T1048)
Menace	Exfiltration des données personnelles de 15 000 clients
Vulnérabilité	Plugins WooCommerce non mis à jour, absence de WAF applicatif renforcé
Vraisemblance brute	3 — Élevée (CVE WordPress/WooCommerce publiées régulièrement)
Impact brut	4 — Critique (amende CNIL jusqu'à 4% CA = 128 000€ + notification 72h + perte confiance)
Criticité brute	[ELEVE] 12/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.28 (Secure coding), A.8.22 (Web filtering), A.8.11 (Data masking)
Actions de traitement	1/ Activation Cloudflare WAF règles OWASP Top 10 ; 2/ Chiffrement colonne email+adresse en BDD ; 3/ Politique mise à jour plugins (délai max 72h après CVE critique) ; 4/ Pen test annuel WooCommerce
Vraisemblance résiduelle	2
Impact résiduel	4 (données sensibles -> impact RGPD inchangé même avec moins de données exposées)
Criticité résiduelle	[ELEVE] 8/16

Champ	Valeur
Responsable	DSI + DPO — Thomas Rivet + Sophie Blanc
Échéance	T2 2026 (urgent)
NIS2 Art. 21	(b) Gestion des incidents, (e) Sécurité de la chaîne d'approvisionnement, (i) Cyberhygiène

R03 — Compromission compte Google Workspace Admin (MFA absent)

Champ	Valeur
Actif ciblé	A-013 (Google Workspace), A-024 (Comptes admin), A-003 (Données RH)
Source de risque	SR-01 (Cybercriminel), SR-03 (Ex-employé)
Vecteur d'attaque	Credential stuffing ou phishing -> accès admin GW -> exfiltration emails/docs (MITRE T1078)
Menace	Prise de contrôle du compte admin -> accès à tous les emails et documents internes
Vulnérabilité	MFA non généralisé sur Google Workspace (seul le DG a le MFA activé)
Vraisemblance brute	4 — Très élevée (credentials stuffing = technique #1, outils automatisés disponibles)
Impact brut	3 — Grave (exfiltration données RH, contrats, accès à tous les services connectés GW)
Criticité brute	[ELEVE] 12/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.5 (Secure authentication), A.5.18 (Access rights), A.8.2 (Privileged access)
Actions de traitement	1/ Activation MFA obligatoire pour tous les comptes GW sous 30 jours ; 2/ Politique mot de passe (min 14 car, pas de réutilisation) ; 3/ Revue trimestrielle des comptes et droits
Vraisemblance résiduelle	1
Impact résiduel	3
Criticité résiduelle	[OK] 3/16
Responsable	DSI — Thomas Rivet
Échéance	Immédiat — Juillet 2026
NIS2 Art. 21	(a) Politique de sécurité, (i) Cyberhygiène et formation

R04 — Indisponibilité fournisseur critique (Stripe)

Champ	Valeur
Actif ciblé	A-015 (Stripe), A-011 (WooCommerce)
Source de risque	SR-05 (Fournisseur — incident technique ou cyberattaque tiers)
Vecteur d'attaque	Panne infrastructure Stripe OU cyberattaque sur Stripe -> 0 paiement CB possible
Menace	Interruption totale des paiements en ligne
Vulnérabilité	Dépendance unique à Stripe (aucun PSP de secours configuré)
Vraisemblance brute	2 — Faible (Stripe SLA 99.99% historique, mais incidents réels en 2023, 2024)
Impact brut	4 — Critique (100% des paiements CB bloqués = ~8 750€/jour de CA perdu)
Criticité brute	[ELEVE] 8/16
Stratégie	Transférer + Réduire
Contrôles ISO 27001	A.5.19 (Supplier security), A.5.21 (ICT supply chain), A.8.14 (Redundancy)
Actions de traitement	1/ Intégrer PayPal comme PSP de secours activable en < 4h ; 2/ SLA contractuel Stripe documenté ; 3/ Procédure de bascule testée annuellement
Vraisemblance résiduelle	2
Impact résiduel	2 (PayPal de secours réduit l'impact)
Criticité résiduelle	[OK] 4/16
Responsable	DSI + Direction — Thomas Rivet + Marie Laurent
Échéance	T3 2026
NIS2 Art. 21	(c) Continuité des activités, (h) Sécurité de la chaîne d'approvisionnement

R05 — Accès non autorisé à l'ERP Odoo (ex-employé)

Champ	Valeur
Actif ciblé	A-012 (Odoo ERP), A-003 (Données RH), A-001 (Données clients)
Source de risque	SR-03 (Ex-employé malveillant)
Vecteur d'attaque	Utilisation des identifiants non désactivés -> accès Odoo -> exfiltration/sabotage
Menace	Consultation ou modification frauduleuse des données ERP par un ancien employé
Vulnérabilité	Absence de procédure de désactivation formalisée lors des départs (offboarding)
Vraisemblance brute	3 — Élevée (turnover PME = fréquent, processus RH informel)

Champ	Valeur
Impact brut	3 — Grave (fraude, sabotage commandes, fuite données clients/RH)
Criticité brute	[ELEVE] 9/16
Stratégie	Réduire
Contrôles ISO 27001	A.5.18 (Access rights), A.6.5 (Responsibilities after termination), A.8.2 (Privileged access)
Actions de traitement	1/ Procédure offboarding formalisée (checklist désactivation J0) ; 2/ Revue des comptes actifs Odoo/GW mensuelle ; 3/ Alertes connexions hors heures ouvrées
Vraisemblance résiduelle	1
Impact résiduel	3
Criticité résiduelle	[OK] 3/16
Responsable	DSI + DRH
Échéance	T2 2026
NIS2 Art. 21	(a) Politique de sécurité, (i) Cyberhygiène

R06 — Injection SQL sur WooCommerce

Champ	Valeur
Actif ciblé	A-011 (WooCommerce), A-001 (BDD clients)
Source de risque	SR-02 (Script kiddie), SR-01 (Cybercriminel)
Vecteur d'attaque	Requête SQL malformée via formulaire de recherche/commande -> accès BDD (MITRE T1190)
Menace	Extraction ou modification de la base de données WooCommerce
Vulnérabilité	Plugins tiers sans validation des entrées, WordPress core non à jour
Vraisemblance brute	3 — Élevée (SQLi = OWASP A03:2021, exploitation automatisée courante)
Impact brut	3 — Grave (accès BDD clients = breach RGPD, perte intégrité commandes)
Criticité brute	[ELEVE] 9/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.28 (Secure coding), A.8.8 (Vulnerability management), A.8.22 (Web filtering/WAF)
Actions de traitement	1/ Activer règles WAF SQLi Cloudflare ; 2/ Audit plugins (supprimer les non maintenus) ; 3/ Politique mise à jour WordPress/plugins (délai 72h CVE critique) ; 4/ WPScan mensuel (automatisé)

Champ	Valeur
Vraisemblance résiduelle	2
Impact résiduel	3
Criticité résiduelle	[MODERE] 6/16
Responsable	DSI — Thomas Rivet
Échéance	T2 2026
NIS2 Art. 21	(e) Sécurité de la chaîne d'approvisionnement, (i) Cyberhygiène

R07 — Non-conformité RGPD transfert AWS us-east-1

Champ	Valeur
Actif ciblé	A-009 (Sauvegardes), A-021 (AWS S3), A-001 (BDD clients)
Source de risque	SR-06 (Erreur interne — configuration héritée)
Vecteur d'attaque	Contrôle CNIL / plainte client -> constat transfert hors UE sans garanties adéquates
Menace	Sanction CNIL + mise en demeure pour transfert de données UE vers USA sans SCC
Vulnérabilité	Réplication S3 configurée sur us-east-1 sans DPA/SCC documenté
Vraisemblance brute	4 — Très élevée (contrôles CNIL en hausse, transferts US = priorité d'investigation)
Impact brut	3 — Grave (amende jusqu'à 20M€ ou 4% CA + obligation de rapatriement immédiat)
Criticité brute	[ELEVE] 12/16
Stratégie	Réduire
Contrôles ISO 27001	A.5.33 (Protection of records), A.5.34 (Privacy and PII)
Actions de traitement	1/ Migration réplication S3 vers eu-west-3 uniquement (action < 30 jours) ; 2/ Signature AWS DPA avec SCC ; 3/ Documentation registre des traitements RGPD
Vraisemblance résiduelle	1
Impact résiduel	2
Criticité résiduelle	[OK] 2/16
Responsable	DPO + DSI — Sophie Blanc + Thomas Rivet
Échéance	Immédiat — Juillet 2026
NIS2 Art. 21	(a) Politique de sécurité, (j) Pratiques de base en matière de cyberhygiène

R08 — Panne matérielle serveurs OVH

Champ	Valeur
Actif ciblé	A-019 (Serveurs OVH WooCommerce), A-020 (Odoo)
Source de risque	SR-06 (Incident technique / force majeure)
Vecteur d'attaque	Défaillance hardware OVH -> indisponibilité site + ERP
Menace	Interruption de service non planifiée
Vulnérabilité	Pas de serveur de secours (cold standby) documenté
Vraisemblance brute	2 — Faible (SLA OVH 99.9%, mais incendie datacenter SBG2 mars 2021 = précédent réel)
Impact brut	3 — Grave (interruption ventes, ERP indisponible)
Criticité brute	[MODERE] 6/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.14 (Redundancy), A.8.13 (Backup), A.5.29 (Business continuity)
Actions de traitement	1/ Snapshot OVH quotidien activé ; 2/ PRA documenté (RTO < 4h, RPO < 24h) ; 3/ Test de restauration semestriel
Vraisemblance résiduelle	2
Impact résiduel	2
Criticité résiduelle	[OK] 4/16
Responsable	DSI — Thomas Rivet
Échéance	T3 2026
NIS2 Art. 21	(c) Continuité des activités et gestion des crises

R09 — Intrusion réseau (WiFi non segmenté)

Champ	Valeur
Actif ciblé	A-022 (Postes de travail), A-023 (VPN WireGuard)
Source de risque	SR-02 (Script kiddie), SR-01 (Cybercriminel)
Vecteur d'attaque	Connexion WiFi invité -> pivot réseau interne -> accès postes/VPN (MITRE T1046 -> T1021)
Menace	Accès au réseau interne depuis le WiFi invité
Vulnérabilité	WiFi invité et WiFi employés sur le même segment réseau
Vraisemblance brute	3 — Élevée (bureaux en open space, WiFi accessible aux visiteurs)
Impact brut	2 — Significatif
Criticité brute	[MODERE] 6/16
Stratégie	Réduire

Champ	Valeur
Contrôles ISO 27001	A.8.20 (Network security), A.8.21 (Security of network services)
Actions de traitement	1/ VLAN séparé WiFi invité (isolation totale) ; 2/ VPN obligatoire pour accès aux systèmes internes
Vraisemblance résiduelle	1
Impact résiduel	2
Criticité résiduelle	[OK] 2/16
Responsable	DSI
Échéance	T3 2026
NIS2 Art. 21	(i) Cyberhygiène et formation

R10 — Malware via phishing (postes employés)

Champ	Valeur
Actif ciblé	A-022 (Postes de travail), A-013 (Google Workspace)
Source de risque	SR-01 (Cybercriminel)
Vecteur d'attaque	Email de phishing -> pièce jointe malveillante -> malware -> pivot réseau (MITRE T1566.001)
Menace	Infection poste de travail -> propagation réseau ou vol de credentials
Vulnérabilité	Absence de formation anti-phishing, pas d'EDR sur les postes
Vraisemblance brute	4 — Très élevée (phishing = vecteur #1 en France en 2025, PME = cibles privilégiées)
Impact brut	2 — Significatif
Criticité brute	[ELEVE] 8/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.7 (Anti-malware), A.6.3 (Awareness training), A.8.5 (Secure authentication)
Actions de traitement	1/ Formation anti-phishing annuelle (simulation) ; 2/ Antivirus EDR déployé sur tous les postes ; 3/ Filtrage DNS malveillant (Cloudflare Gateway)
Vraisemblance résiduelle	2
Impact résiduel	2
Criticité résiduelle	[OK] 4/16
Responsable	DSI + RH (formation)
Échéance	T3 2026
NIS2 Art. 21	(b) Gestion des incidents, (i) Cyberhygiène et formation

R11 — Sauvegarde corrompue ou non testée

Champ	Valeur
Actif ciblé	A-009 (Sauvegardes AWS S3), A-001 (BDD clients), A-002 (Commandes)
Source de risque	SR-06 (Erreur interne), SR-01 (Ransomware chiffrant aussi les backups)
Vecteur d'attaque	Ransomware chiffrant le bucket S3 non protégé OU corruption silencieuse non détectée
Menace	Impossibilité de restaurer après incident — perte définitive de données
Vulnérabilité	Sauvegardes sur bucket S3 accessible depuis le même compte AWS (pas d'immuabilité)
Vraisemblance brute	2 — Faible (incident potentiel mais non encore testé = découverte lors d'une crise)
Impact brut	4 — Critique (perte définitive des données = fin d'activité potentielle)
Criticité brute	[ELEVE] 8/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.13 (Backup), A.8.14 (Redundancy)
Actions de traitement	1/ Activer S3 Object Lock (WORM — Write Once Read Many) ; 2/ Test de restauration complet trimestriel documenté ; 3/ Backup secondaire hors AWS (OVH Object Storage)
Vraisemblance résiduelle	1
Impact résiduel	3
Criticité résiduelle	[OK] 3/16
Responsable	DSI
Échéance	T2 2026
NIS2 Art. 21	(c) Continuité des activités

R12 — Accès non autorisé aux données RH

Champ	Valeur
Actif ciblé	A-003 (Données RH), A-012 (Odoo HR), A-013 (Google Workspace)
Source de risque	SR-03 (Employé curieux ou malveillant)
Vecteur d'attaque	Accès direct à Odoo HR sans contrôle de rôle -> consultation fiches de paie collègues
Menace	Violation de la confidentialité des données RH (Art. 9 RGPD — données sensibles)

Champ	Valeur
Vulnérabilité	Rôles Odoo mal configurés (accès trop larges pour certains profils)
Vraisemblance brute	2 — Faible
Impact brut	3 — Grave (RGPD + conflit social + litige prud'homal)
Criticité brute	[MODERE] 6/16
Stratégie	Réduire
Contrôles ISO 27001	A.5.15 (Access control), A.5.18 (Access rights)
Actions de traitement	1/ Audit et reconfiguration des rôles Odoo HR ; 2/ Principe du moindre privilège appliqué
Vraisemblance résiduelle	1
Impact résiduel	3
Criticité résiduelle	[OK] 3/16
Responsable	DRH + DSI
Échéance	T3 2026
NIS2 Art. 21	(a) Politique de sécurité

R13 — Configuration VPN WireGuard défaillante

Champ	Valeur
Actif ciblé	A-023 (VPN WireGuard), A-019/A-020 (Serveurs OVH)
Source de risque	SR-02 (Script kiddie), SR-06 (Erreur de configuration)
Vecteur d'attaque	Port WireGuard exposé + mauvaise configuration -> accès au réseau d'administration
Menace	Accès non autorisé à l'infrastructure d'administration via VPN mal configuré
Vulnérabilité	Configuration initiale non audité, clés de rotation jamais effectuée
Vraisemblance brute	2 — Faible
Impact brut	3 — Grave (accès admin = compromission totale possible)
Criticité brute	[MODERE] 6/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.20 (Network security), A.8.9 (Configuration management)
Actions de traitement	1/ Audit configuration WireGuard (pairs autorisés, AllowedIPs) ; 2/ Rotation des clés annuelle ; 3/ Log des connexions VPN
Vraisemblance résiduelle	1
Impact résiduel	3

Champ	Valeur
Criticité résiduelle	[OK] 3/16
Responsable	DSI
Échéance	T3 2026
NIS2 Art. 21	(i) Cyberhygiène

R14 — Contournement WAF Cloudflare (règles obsolètes)

Champ	Valeur
Actif ciblé	A-017 (Cloudflare), A-011 (WooCommerce)
Source de risque	SR-01 (Cybercriminel avancé)
Vecteur d'attaque	Technique d'évasion WAF (encodage, fragmentation) -> bypass filtres Cloudflare
Menace	Attaque applicative (SQLi, XSS) contournant le WAF
Vulnérabilité	Règles WAF personnalisées jamais mises à jour depuis déploiement
Vraisemblance brute	2 — Faible
Impact brut	3 — Grave
Criticité brute	[MODERE] 6/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.22 (Web filtering), A.8.8 (Vulnerability management)
Actions de traitement	1/ Revue trimestrielle des règles WAF Cloudflare ; 2/ Activation mode "Managed Rules" OWASP
Vraisemblance résiduelle	1
Impact résiduel	3
Criticité résiduelle	[OK] 3/16
Responsable	DSI
Échéance	T3 2026
NIS2 Art. 21	(i) Cyberhygiène

R15 — Défacement du site (plugin WordPress vulnérable)

Champ	Valeur
Actif ciblé	A-011 (WooCommerce)
Source de risque	SR-02 (Script kiddie)

Champ	Valeur
Vecteur d'attaque	Exploitation CVE plugin WordPress -> RCE -> modification contenu site
Menace	Défacement ou injection de contenu malveillant sur le site e-commerce
Vulnérabilité	Plugins non mis à jour, 47 plugins installés dont 12 non maintenus
Vraisemblance brute	3 — Élevée
Impact brut	2 — Significatif (impact réputation, correction rapide possible)
Criticité brute	[MODERE] 6/16
Stratégie	Réduire
Contrôles ISO 27001	A.8.8 (Vulnerability management), A.8.28 (Secure coding)
Actions de traitement	1/ Audit et désinstallation plugins non maintenus ; 2/ WPScan automatisé (voir poc/wpscan)
Vraisemblance résiduelle	2
Impact résiduel	2
Criticité résiduelle	[OK] 4/16
Responsable	DSI
Échéance	T2 2026
NIS2 Art. 21	(i) Cyberhygiène

Synthèse du portefeuille de risques

Tableau de bord — Risques bruts

Niveau	Risques	IDs
[CRITIQUE] Critique (13-16)	0	—
[ELEVE] Élevé (9-12)	6	R01, R02, R03, R05, R06, R07
[MODERE] Modéré (5-8)	7	R04, R08, R09, R10, R11, R12, R13, R14, R15
[OK] Faible (1-4)	2	—
Total	15	

Tableau de bord — Risques résiduels (après traitement)

Niveau	Risques	IDs
[CRITIQUE] Critique (13-16)	0	—

Niveau	Risques	IDs
[ELEVE] Élevé (9-12)	1	R02 (données clients — impact RGPD structurel)
[MODERE] Modéré (5-8)	2	R01, R06
[OK] Faible (1-4)	12	Tous les autres
Total	15	

Lecture : Le traitement des risques ramène 6 risques élevés à 1 seul risque élevé résiduel (R02). Ce risque résiduel est accepté par la direction car il est structurel au traitement de données personnelles dans un contexte e-commerce — il ne peut pas être éliminé, seulement réduit.

Risques acceptés par la direction

ID	Risque résiduel	Score résiduel	Justification
R02	Fuite données clients	[ELEVE] 8/16	Risque structurel e-commerce, mesures techniques maximales déployées

Actions prioritaires (Quick Wins — délai < 30 jours)

Priorité	Action	Risque adressé	Effort	Impact
1	Activation MFA Google Workspace (tous comptes)	R03	Faible (< 2h)	Criticité 12 -> 3
2	Migration réplication S3 eu-west-3 uniquement	R07	Moyen (1 jour)	Criticité 12 -> 2
3	Activation S3 Object Lock (WORM)	R11	Faible (< 1h)	Criticité 8 -> 3
4	Procédure offboarding formalisée	R05	Faible (< 4h)	Criticité 9 -> 3

Références

Contrôle	Référence
Méthode d'analyse	EBIOS Risk Manager — ANSSI 2018
Gestion du risque	ISO/IEC 27005:2022
Contrôles de sécurité	ISO/IEC 27001:2022 Annex A
Techniques d'attaque	MITRE ATT&CK; Enterprise v14
Conformité RGPD	Règlement UE 2016/679 — Art. 32 (sécurité), Art. 46 (transferts)
NIS2	Directive UE 2022/2555 — Article 21

Document produit dans le cadre du SMSI TechShop SAS — Projet portfolio GRC Automation

Prochaine révision : Décembre 2026 (revue annuelle obligatoire ISO 27001 Clause 8.2)